

คู่มือการบริหารจัดการ

Web Application Platform

แนวทางปฏิบัติในการดูแลระบบ (LAMP/LEMP Stack) สำหรับ System Admin, Software Developer และ DBA เพื่อความเสถียร ปลอดภัย และมีประสิทธิภาพ

โครงสร้างหลัก 5 มิติ

การบริหารจัดการแพลตฟอร์มอย่างเป็นระบบ จำเป็นต้องครอบคลุมทุกมิติของการทำงาน เพื่อให้สอดคล้องกับหลักความปลอดภัยและประสิทธิภาพ:

มิติที่ 1: การจัดการผู้ใช้งานและสิทธิ์ (Access Control)

มิติที่ 2: โครงสร้างพื้นฐาน (OS & Infra)

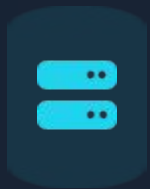
มิติที่ 3: Web Server Management

มิติที่ 4: Database Management

มิติที่ 5: ความปลอดภัยและการสำรองข้อมูล



บทบาทและสิทธิ์การเข้าถึง (Roles & Permissions)



System Admin

หน้าที่: ดูแลภาพรวมของ OS, Network, Security และ Service ทั้งหมด

สิทธิ์ OS: Full Root Access ผ่าน sudo (กลุ่ม sysadmin)



Software Dev

หน้าที่: Deploy โค้ด, แก้ไขเว็บไซต์, ดู Log การทำงาน

สิทธิ์ OS: จัดการไฟล์ใน /var/www/html, อ่าน Log, สั่ง Restart Web Server ได้แบบจำกัด



DB Admin (DBA)

หน้าที่: ปรับปรุง MySQL, Backup/Restore, ดูแล Database Users

สิทธิ์ OS: จัดการ MySQL Service/Config, สิทธิ์ระดับ Admin ใน phpMyAdmin

มิตินี้ 1: การจัดการผู้ใช้งาน (User Management)



หลักการ Least Privilege

หัวใจสำคัญคือการให้สิทธิ์เท่าที่จำเป็น โดยใช้ Linux Groups (sysadmin, webdev, dbadmin) และไฟล์ sudoers ในการควบคุม



การจัดการสิทธิ์ระดับ Web Directory

กำหนดให้กลุ่ม webdev เป็นเจ้าของโฟลเดอร์ /var/www/html และใช้ SGID (chmod 2775) เพื่อให้ไฟล์สร้างใหม่สืบทอดสิทธิ์กลุ่มเสมอ



การตั้งค่า Sudoers แบบจำกัด

อนุญาตให้ Dev และ DBA สั่งรันคำสั่งเฉพาะที่จำเป็น เช่น รีสตาร์ท Service (NGINX/MySQL) หรือดูสถานะ โดยไม่ต้องใช้รหัสผ่าน Root

มิตีที่ 2: โครงสร้างพื้นฐาน (OS & Infra)

Patch & Monitoring

- ▶ **Patch Management:** อัปเดต Security Patchสม่ำเสมอ และตั้งค่า unattended-upgrades สำหรับแพตช์ความปลอดภัยอัตโนมัติ
- ▶ **Resource Monitoring:** เฝ้าระวัง CPU, RAM, Disk I/O ด้วยเครื่องมือพื้นฐาน (htop) หรือระดับองค์กร (Prometheus + Grafana, Zabbix)

Network & Firewall

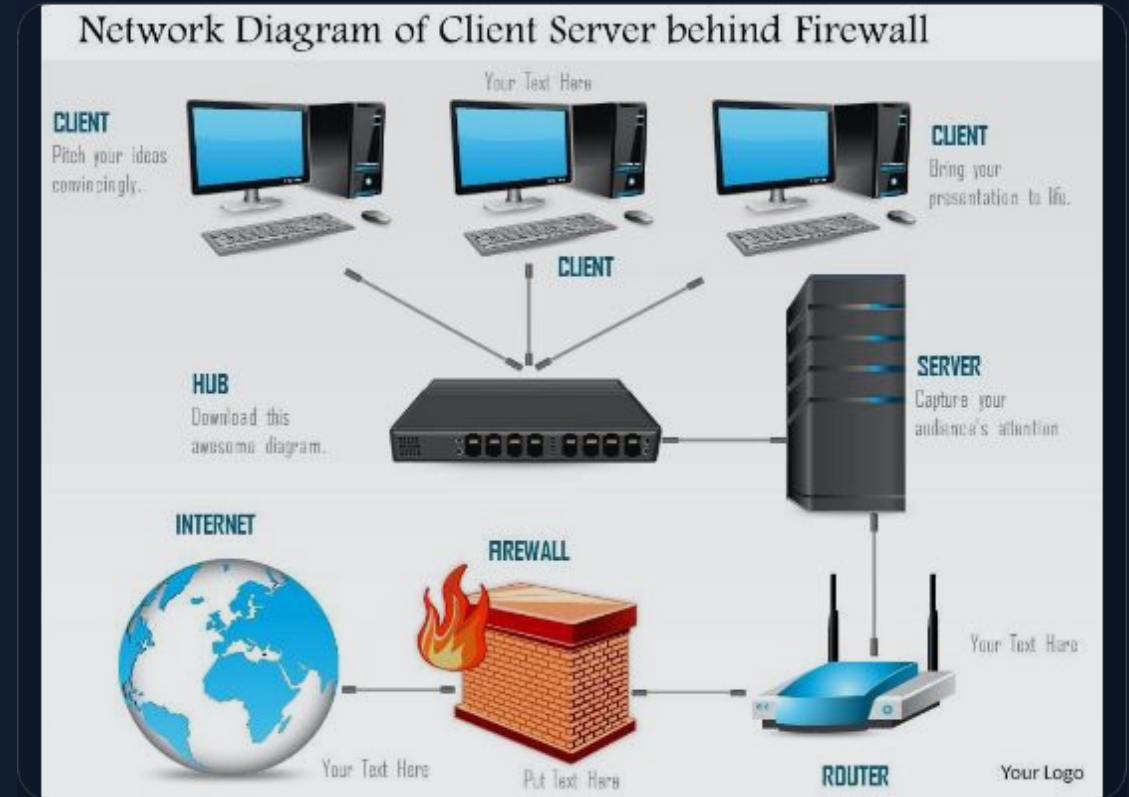
- ▶ **UFW (Uncomplicated Firewall):** เปิดเฉพาะพอร์ตที่จำเป็นเท่านั้น
- ▶ **พอร์ตสาธารณะ:** อนุญาตเฉพาะ 80 (HTTP) และ 443 (HTTPS)
- ▶ **พอร์ตจำกัด:** Port 22 (แนะนำให้เปลี่ยนพอร์ต) และ Port 3306 (MySQL) ห้ามเปิด Public ให้เข้าผ่าน VPN หรือ Localhost เท่านั้น

มิติที่ 3: Web Server Management

การจัดการระดับ Web Server ต้องเน้นที่ความปลอดภัยและประสิทธิภาพ (ร่วมกันดูแลโดย SysAdmin และ Dev):

มาตรฐานที่ต้องมีเหมือนกัน

- ▶ บังคับใช้ HTTPS ด้วย SSL/TLS Certificate (Let's Encrypt)
- ▶ จัดการ Log สำเนาเสมอ (access/error) พร้อมตั้งค่า Logrotate
- ▶ **กรณีใช้ Apache:** ใช้ Virtual Hosts แยกคอนฟิก เปิดเฉพาะ Module ที่จำเป็น ปรับจูน MPM Event/Worker
- ▶ **กรณีใช้ NGINX (แนะนำ):** ใช้ Server Blocks, ตั้งค่าเป็น Reverse Proxy คู่กับ FastCGI Cache เพื่อลดโหลด และจูน Worker Processes



มิตีที่ 4: Database Management

MySQL Server

- ▶ **Performance:** ปรับจูนค่า
innodb_buffer_pool_size (50-70% ของ RAM),
max_connections
- ▶ **Security:** ห้าม Web App ต่อด้วยสิทธิ์ root ให้สร้าง User เฉพาะและจำกัดสิทธิ์ (SELECT, INSERT, UPDATE, DELETE)
- ▶ **Optimization:** เปิด Slow Query Log เพื่อให้ Dev นำไปวิเคราะห์และปรับปรุง SQL

phpMyAdmin Security

- ▶ **Obfuscation:** เปลี่ยน URL ทางเข้าเป็นชื่อที่คาดเดายาก (เช่น /db-manage-app)
- ▶ **Access Control:** ปิดการล็อกอินด้วย root (AllowRoot = false)
- ▶ **Protection:** จำกัด IP ที่สามารถเข้าถึงได้, ใช้ .htpasswd กรองอีกชั้น หรือเปิดใช้งาน 2FA

มิตีที่ 5: Server Hardening

การป้องกันระดับ OS

เสริมความแข็งแกร่งให้กับเซิร์ฟเวอร์เพื่อป้องกันการโจมตีจากภายนอก:

SSH Security

ปิดการเข้าสู่ระบบด้วย Password บังคับใช้ SSH Key เท่านั้น และปิดไม่ให้ Root ล็อกอินโดยตรง (PermitRootLogin no)

Intrusion Prevention

ติดตั้งซอฟต์แวร์ **Fail2Ban** เพื่อบล็อก IP Address ที่พยายามเดารหัสผ่าน SSH หรือส่ง Request มาที่ Web Server ผิดปกติเกินจำนวนที่กำหนด



Backup & Disaster Recovery (DR)

2. Retention Policy

กำหนดนโยบายจัดเก็บ: รายวันย้อนหลัง 7 วัน,
รายสัปดาห์ 4 สัปดาห์ และรายเดือน 6 เดือน

1. Automation

สำรองไฟล์ (/var/www/html) และ
Database (mysqldump) เป็นประจำทุกวัน
ส่งขึ้น Cloud Storage

3. Test Restore

ซ้อมกู้คืนข้อมูลอย่างน้อยไตรมาสละ 1 ครั้ง
เพื่อให้มั่นใจว่าไฟล์ Backup สมบูรณ์และใช้งาน
ได้จริง

** สำหรับระบบ Critical ควรทำ MySQL Replication (Master-Slave) เพื่อลดความเสี่ยง*

สรุป Workflow การทำงานแบบบูรณาการ



1. Deployment & Fixes

Dev Push Code ขึ้น Server เช็ค Error จาก Web Log และสามารถสั่ง Restart Web Service ได้เองอย่างปลอดภัย



2. Performance Tuning

เมื่อระบบช้า **Dev & DBA** วิเคราะห์ Slow Query ร่วมกัน DBA ปรับ Index ส่วน Dev ปรับปรุงโค้ด SQL



3. Maintenance

SysAdmin ดูแลความปลอดภัย อัปเดตแพตช์ มอนิเตอร์ Traffic และจัดการสิทธิ์ผู้ใช้ในระบบทั้งหมด